

PRODUCTION_READINESS_PLAN

Helix OTA — Production-Readiness Assessment & Phased Delivery Plan

Revision: 1 **Last modified:** 2026-07-12T00:00:00Z **Authority:** §11.4.172 (living production-readiness planning doc) · §11.4.93 (workable-items DB load-list) · §11.4.6 (no-guessing — every claim cites a path; unknowns marked UNCONFIRMED:.) **Scope:** the whole Helix OTA monorepo — Go control plane (server/), the six ota-* bricks + other owned submodules, the two web frontends (clients/ota-manager/, dashboard/), the (unbuilt) marketing website, containers/dev-infra, and the multi-track/tracking machinery. **Method:** authored from a direct read of .superpowers/sdd/progress.md, docs/CONTINUATION.md, docs/features/Status.md, docs/Issues.md, config/multitrack/the-factory.yaml, docs/research/accounts/*, docs/research/website/*, plus four independent evidence-cited survey passes (server / submodules+gitlinks / web-frontends+website / test-type matrix). FACT = read this session; UNCONFIRMED = flagged inline.

1. EXECUTIVE SUMMARY

Verdict — the control-plane CORE is strong and well-tested; the SYSTEM is not production-ready. The Go/Gin control plane (server/) compiles clean (cd server && go build ./... → exit 0, FACT), carries deep multi-type test coverage (unit/integration/stress/chaos/fuzz/security/concurrency/race/memory/benchmark), and both store backends (in-memory + real pgx/PostgreSQL) are compiled in and runtime-selectable (server/cmd/ota-server/main.go:46-82). The emulated Android A/B path is genuinely proven end-to-end (Cuttlefish Tier-2 on nezha, docs/qa/20260623-cuttlefish-tier2-ab/; OTA-003

Completed). But the *deliverable product* the operator described — a multi-tenant, self-hostable OTA platform with a project CLI, a device update client + setup wizard, a marketing website, and validated on-silicon RK3588 updates — is substantially **unbuilt or unproven**: multi-tenant Accounts is design-complete but not implemented, the website does not exist, the on-device Linux/U-Boot apply path is a scaffold, and the physical-board Tier-3 apply + §11.4.185 manual-QA final gate are operator-blocked. No release tag exists (greenfield, FACT docs/research/accounts/30_delivery_plan.md:70).

Top 5 risks (production-blocking, risk-descending):

1. **Predictable dev token secret + no fail-fast (security).** server/internal/config/config.go:180-184 — when HELIX_TOKEN_SECRET is unset the HMAC signing key silently defaults to the literal "helix-ota-dev-token-secret-change-me"; the server boots with a publicly-known signing key and no warning. Under the forthcoming multi-tenant Accounts layer this is catastrophic (an attacker mints a token with ANY account_id claim → total tenant-isolation defeat) — flagged as the single highest-severity as-is finding in docs/research/accounts/30_delivery_plan.md:392-399.
2. **No graceful shutdown (ops).** server/cmd/ota-server/main.go:142-148 calls ListenAndServe/tsrv.Start() with no os/signal handling and no http.Server.Shutdown/drain — on SIGTERM in-flight requests are dropped; no rolling-deploy safety.
3. **No observability (ops).** No /metrics (Prometheus), no tracing/OpenTelemetry, no structured logging (stdlib log only) — a production fleet-update system with no metrics/traces is operationally blind (server survey §7, FACT).
4. **Physical-target apply unproven + operator-blocked (correctness).** The on-device Linux/U-Boot ApplyPort is an explicit SCAFFOLD (server/internal/device/applyport.go:10-16); RK3588 Tier-3 on-silicon A/B (vendor HAL, U-Boot slot-switch, real-partition dm-verity) is OPERATOR-BLOCKED on hardware (OTA-004, docs/Issues.md:26-44); the §11.4.185 manual-QA final confirmation on the fielded target is therefore unsatisfied.
5. **Object storage is a placeholder (correctness/e2e).** Uploaded artifact bytes are validated then discarded — StorageRef is a placeholder, no real object store in-repo (docs/research/accounts/30_delivery_plan.md:407-413). Any “device downloads + applies the exact bytes” e2e is unprovable until a real Storage seam lands, so the full OTA loop is proven only in the emulated/container tier, not byte-for-byte over real storage.

Honest positives (so the plan is proportionate): server trust boundary is correct (artifact verify key comes only from config, never the request — `server/internal/config/config.go:73-77`); pgx path is real + migrated-on-boot + integration-tested against real Postgres; HB-2 fabric-lease dev/prod divergence is already closed (03340896); the dashboard has strong §11.4.170 host-render proof (26 goldens); the OTA Go bricks are clean, decoupled, and test-backed.

2. UNFINISHED — incomplete features / components / wiring (each cited)

2.1 Multi-tenant Accounts — DESIGNED, not tenant-isolating

- **Design complete, implementation gated.** Full 11-doc research/design set `docs/research/accounts/00_INDEX.md ... 30_delivery_plan.md` (Rev 2, 2026-07-10) — 8-milestone delivery plan M1–M8, status “as-is discovery COMPLETE; to-be design phase ... implementation gated on operator approval” (`00_INDEX.md:5`).
- **Partial skeleton exists but is NOT multi-tenant** (server survey §4, FACT): `store.Project/ProjectRole/ProjectAccess` types (`server/internal/store/store.go:287-311`), project CRUD routes (`server/internal/api/server.go:246-250`), `requireProjectAccess` helper (`handlers_project.go:37`), creator-admin ACL seed (`handlers_project.go:147`). GAPS: core resource tables (`devices/artifacts/releases/deployments/telemetry`) carry **no project_id/account_id column** → no data-level tenant isolation; there is **no account/org/tenant entity anywhere** (`accounts/00_INDEX.md:137-143`); no persisted User (identity is the token subject, env-seeded in-memory map); membership-management routes (`POST/DELETE /projects/:id/members`) are not mounted, and `ListProjectMembers/RemoveProjectAccess` repo methods are unreferenced.

2.2 Project website (§11.4.190) — ABSENT (planning-only)

- No `website/site/www/` source dir; no website entry in `.gitmodules`; `submodules/website` does **not** exist (FACT, verified this session). Firebase hosts only the two admin SPAs, both `noindex` (`firebase.json`, `.firebaseerc`) — not a marketing surface.

- Only planning exists: docs/research/website/
00_WEBSITE_DESIGN_AND_BUILD_PLAN.md +
01_SCAFFOLD_READINESS_AND_VERIFICATION.md (Rev 2) — planned as a
NEW submodule submodules/website, Angular 22 SSR + Tailwind v4
+ an OpenDesign “Helix-green” brand layer, dark/light + i18n,
content LOCKED (sales email contact@hxota.com, **NO pricing**, “Made
with ♥ by Helix Development team” footer). 3 operator decisions
open (\$8.6 of the plan).

2.3 Device-side min_current_version — server-only, wire field ABSENT

- Server enforces the floor (server/internal/api/handlers_client.go:63-76, SRV-1 87305ca1) but the device-facing offer struct UpdateAvailable (submodules/ota-protocol/types.go:87-108) carries **no MinCurrentVersion field** — it exists only on the server-side Release struct (types.go:50). The Kotlin device DTOs also lack it. The follow-up (add min_current_version to UpdateAvailable + the Kotlin UpdateAvailable DTO in ota-android-agent, then enforce device-side to mirror SRV-1) is real and unstarted.

2.4 On-device Linux/U-Boot ApplyPort — SCAFFOLD

- server/internal/device/applyport.go:10-16 header: “SCAFFOLD — the ApplyPort methods are stubs ... the slot-writer and full ApplyPort driver (Step a → f loop) are DESIGNED but NOT wired.” fwenv.go shell-out is authored; the apply loop / SlotWriter is not. server/cmd/applyport/main.go:357 — // ... For now return a placeholder. (Note: the emulated Cuttlefish + QEMU A/B path IS proven — this gap is the real-partition Linux path, entangled with OTA-004.)

2.5 pgx/PostgreSQL store — WIRED, but production-operation not hardened

- CORRECTION to a common assumption: the Postgres path is **not** integration-tag-gated dead code — postgres.go/postgres_fabric.go/rollout/postgres.go carry no //go:build line and ship in the binary; selection is the runtime env var HELIX_DATABASE_URL (config.go:112-134, main.go:46-82), migrated on boot with a 60s connect-retry. In-memory (main.go:80) is the default when unset. What is UNFINISHED is production *operation* hardening around it

(graceful shutdown, connection-pool observability, secret fail-fast)
— see §2.7.

2.6 Parent-repo gitlink bumps lagging (trunk hygiene)

- **llm_orchestrator gitlink LAGS by 2 commits (FACT):** recorded pointer 7e3e6da, submodule HEAD c41a264 (Wave-22 LO-1.4), `git submodule status` shows the + dirty marker → parent must bump 7e3e6da → c41a264.
- **containers:** the main-repo checkout's gitlink is 4774eda (Wave-18c) and equals the submodule HEAD (no +). The Wave-21/SW6 containers hardening (progress ledger 047fbfc) lives on feature/containers-hardening in a *separate* track checkout (§11.4.179 own-.git), **not** in this main tree — `git cat-file -t 047fbfc` → “Not a valid object name” here. So on main this is not a lag but a pending §11.4.191 feature → main merge. (The .superpowers/sdd/progress.md “Wave-21 047fbfc landed” line is written from the track-3 checkout; reconcile the ledger.)

2.7 Server production-readiness wiring gaps (FACT, server survey §7)

- **Graceful shutdown absent** — `main.go:142-148` (no signal handling / `Server.Shutdown`).
- **Token-secret silent dev fallback** — `config.go:180-184` (no fail-fast/warn on the default secret).
- **Observability absent** — no /metrics, tracing, or structured logging.
- **Rate-limiting thin + default-off** — only a global in-flight semaphore `rate_limit.go:9-33`, `HELIX_MAX_INFLIGHT` default 0=disabled (`config.go:60-62`); no per-IP/token throttle, no login brute-force limiter.
- **Auth is an MVP stub** — HMAC opaque token (`token.go:25-30`), static in-memory `UserDirectory` with constant-time compare (GOOD, `users.go:41-44`) but plaintext in-memory passwords + in-memory refresh store (lost on restart). No real IdP/OAuth2.

2.8 Multi-track headless auto-ruler — bootstrapped, operator-gated

- Engine present (`constitution/scripts/multitrack/*`) + per-host config (`config/multitrack/the-factory.yaml`); bootstrap `rc=0`, `cwd`-hook installed, §11.4.178 identity resolver live

(progress.md:132-136). REMAINDER (operator-gated, §11.4.10/ §11.4.187 honest boundary): the `claude1..4` toolkit aliases are **not on PATH** — headless-worker spawn needs per-alias account provisioning + OAuth tokens (external, cannot be done via tools). The system engages the instant aliases are provisioned.

2.9 Config-vs-directive track/branch drift (needs reconciliation)

- config/multitrack/the-factory.yaml focus labels: T2=web dashboard/website, T3=containers-hardening, T4=vm-emu-hardening. The later operator directive (progress.md:53) dispatches **claude1 → T2 accounts, claude3 → T4 website**, and the Accounts delivery plan mandates ONE canonical branch `feature/multi-tenant-accounts` across main+submodules (§11.4.181, accounts/30_delivery_plan.md:37) — which differs from the config’s `feature/accounts-web`. This drift must be reconciled and the canonical (`logic-group → track, branch`) binding recorded ONCE in the workable-items registry (§11.4.181/§11.4.191) before dispatch.

3. UNTESTED / COVERAGE GAPS (per §11.4.169 test-type matrix)

Strong surfaces (FACT, test survey): `server/` control plane (unit/integration[pgx]/stress/chaos/security/fuzz/concurrency/race/memory/benchmark — all present) and the 4 Go OTA bricks (unit/stress/chaos/fuzz/security/concurrency-race). HelixQA OTA banks are genuinely wired (`tools/helixqa/banks/helix_ota.yaml` + Go runner `tools/helixqa_runner/main.go`). Emulated Tier-1 container OTA round-trip + Tier-2 Cuttlefish A/B are proven with committed evidence.

Gaps (risk-ordered):

Gap	Detail (cited)	Severity
Physical RK3588 apply (Tier-3) + §11.4.185 manual QA	Full on-silicon <code>update_engine/</code> U-Boot/dm-verity apply is OPERATOR-BLOCKED (OTA-004, docs/Issues.md:26-44). Board control-plane reachability IS proven (docs/qa/20260622-	HIGH

Gap	Detail (cited)	Severity
	rk3588-controlplane/ REPORT.md) but on nezha- attached serials, not the the- factory.yaml D1/D2 serials (998fd36615e99484/ 66ff9c4f51f00ee7) — no full- apply run on any board. §11.4.185 final manual-QA confirmation on the fielded target is unmet.	
Android bricks under-tested	ota-android-agent + ota- update-engine-bridge have JVM unit tests only (47 + 27 PASS); NO stress/chaos/ benchmark/memory; only the agent has an androidTest/ dir. Real device apply unproven off-emulator (ties to OTA-004).	HIGH
Object-storage byte-level e2e	StorageRef placeholder → “device downloads + applies exact bytes” over real storage is unprovable until a Storage seam lands (accounts/ 30_delivery_plan.md:407-413).	HIGH
True distributed DDoS	Only one bounded live saturation test (tests/ security/saturation_live.sh) + rate_limit_test.go; deployed system.compose.yaml ships the in-flight cap OFF (default 0). No multi-source flood / slowloris; OTA submodules have zero DDoS coverage.	MEDIUM
Web-surface resilience	clients/ota-manager + dashboard have unit + e2e + §11.4.170 host-render but NO stress/chaos/DDoS/memory/ benchmark.	MEDIUM
Submodule bench/memory	The 4 Go bricks have stress+chaos+fuzz but zero	LOW-MEDIUM

Gap	Detail (cited)	Severity
§11.4.170 host-render breadth	Benchmark funcs and no memory/leak tests; no -memprofile anywhere outside server. dashboard/ strong (26 goldens, ~13 screen×state × {light,dark}); clients/ota-manager/ only 2 screens rendered — the feature pages need host-render once routed.	LOW-MEDIUM
Challenges submodule	submodules/challenges/ carries no OTA bank; all OTA challenge coverage rests on tools/helixqa/banks/.	LOW

4. KNOWN ISSUES + OPERATOR DECISIONS

#	Item (cited)	Class	Severity	Who decides
	Mirror-fork canonicalization — vision_engine (main published; master diverges github a97df79 vs origin b417a40); llm_orchestrator (main-vs-master §11.4.181 asymmetry across orgs; gitlink also lags §2.6); llm_provider (main branches a real CODE fork: HelixDev 4749d46 +16.8k lines vs vasic 8905a76 +647). All fixes already published on the canonical branch; force-push forbidden §11.4.113.	Operator decision	Medium	Operator (pick canonical mirror + UNION-merge/retire divergent branches)
K2	Stray submodules/LLMProvider/ dir — untracked duplicate not in .gitmodules (llm_provider is the tracked one).	Cleanup	Low	Agent (remove) / operator confirm
K3	ROLL-1 — SuccessThreshold==0 = any-	Design decision	Low	Operator

#	Item (cited)	Class	Severity	Who decides
K4	success-passes (symmetric canary no-gate) in ota-rollout-engine; reject-in-validatePhases OR document as by-design (progress.md:159). OTA signing metadata not crypto-bound — targeting metadata (OSType/Board/Version) is not signature-bound, so relabel-replay is possible within S4/S5 constraints; framed intentional, hinges on upload-auth + signing spec (progress.md:159).	Security design	Medium	Operator (signing-spec scope)
K5	VAL-1 — ota-artifact-validator/stages.go:15 FALSE comment claims ota-protocol.ValidateArtifactMeta enforces a 255-char Version bound (it only checks empty; real guard is in-package ValidateVersion). Corrective, prevents a future HC-2 regression re-open (progress.md:159).	Doc bug	Low	Agent (fix comment)
K6	Stale fabric-lease comments — server/internal/store/postgres_fabric.go:137-139 still asserts “non-exclusive target may hold multiple concurrent leases” (false since HB-2 03340896 made it uniform); store.go:220-229/:415-417 still frame it as “exclusive target”. Behavior correct; comments misleading.	Doc bug	Low	Agent (fix comments)
K7	HB-1 — server/internal/device/fwenv.go SaveEnv swallows a fw_setenv flush		Medium	Agent (after research)

#	Item (cited)	Class	Severity	Who decides
	error; naive return err false-fails on backends where empty-key-save is unsupported → needs §11.4.8 research on fw_setenv no-args semantics before a safe fix (progress.md:101).	Bug (research-gated)		
K8	SW1-2 — containers pkg/vm/macros/macros.go:262 bootWait timer not Stop()'d on 2 non-timer select branches; darwin-only, weak RED oracle → defensive defer-Stop + pattern-consistency proof (progress.md:116,139).	Bug (low)	Low	Agent (T3)
K9	HB-2 — memory-vs-Postgres fabric-lease divergence: ALREADY CLOSED uniformly (03340896); listed here only because prior ledgers framed it open (server survey §6).	Resolved	—	—
K10	§11.4.185 manual-QA final gate + OTA-004 hardware	Release blocker	High	Operator/QA (attach RK3588 board; run manual confirmation)
K11	Multi-track alias provisioning (§2.8) + track/branch drift (§2.9)	Operator/registry	Medium	Operator (provision toolkit OAuth) + agent (record canonical bindings)
K12	Accounts decision gate — OQ-2 (RBAC-first hybrid), OQ-3 (local accounts), OQ-4 (default-account backfill), per-account signing keys, TEXT-vs-UUID id type (accounts/30_delivery_plan.md:482-498).	Design decision	High (blocks P3)	Operator

#	Item (cited)	Class	Severity	Who decides
K13	Website decisions — repo name/remote, containerized build, tokens-only OpenDesign (website/00_* §8.6).	Design decision	Medium (blocks P4)	Operator
K14	DDoS default posture — HELIX_MAX_INFLIGHT default 0=UNLIMITED (OOM risk); proposed conservative 256 is a §11.4.122 behavior change (progress.md; CONTINUATION §5 Q).	Ops decision	Medium	Operator

5. PHASED PLAN

Ordering principle (§11.4.132 risk-descending): production-critical server + OTA-deploy path first → live on-device validation → the two big features (Accounts, Website) → hardening backlog + tracking hygiene. The two big features (P3/P4) develop as isolated §11.4.167 work-streams on their own branches, trunk-merged regularly (§11.4.188), merged to main ONLY after operator approval + §11.4.185 manual QA. Effort = T-shirt estimate only; §11.4.172 forbids false calendar precision until velocity is measured.

Track/branch map (reconcile per §2.9 before dispatch; canonical bindings recorded once in the registry §11.4.191): - **T1 / main** — trunk hygiene + server production-readiness + OTA-deploy path (config focus: production main). - **T2 / feature/multi-tenant-accounts** — Accounts big feature (delivery-plan canonical branch §11.4.181; supersedes the config's feature/accounts-web label — reconcile). - **T3 / feature/containers-hardening** — containers hardening backlog. - **T4 / feature/website** — new marketing website submodule (+ residual feature/vm-emu-hardening vm/emu backlog).

P0 — Stabilize + publish-pending (T1 / main) — effort S–M

- Bump llm_orchestrator gitlink 7e3e6da → c41a264 (§2.6).
- Fix stale doc comments (K6 fabric-lease, K5 VAL-1); reconcile the progress-ledger containers 047fbfc note (§2.6).
- Surface K1 mirror-fork + K3 ROLL-1 + K14 DDoS-default operator decisions; remove stray submodules/LLMProvider (K2).

- Reconcile track/branch drift + record canonical bindings (§2.9); provision multi-track toolkit aliases (K11, operator).
- Migrate OTA-003 → Fixed.md; refresh stale Status.md (Rev 21, 2026-06-23) + CONTINUATION.md exports.

P1 — Server production-readiness (T1 / main) — effort L

- **Graceful shutdown** (SIGTERM → http.Server.Shutdown drain, both HTTP and QUIC transports) — §2.7.
- **Token-secret fail-fast** (refuse to boot on default/unset HELIX_TOKEN_SECRET) — Risk #1, K-security.
- **Observability** — /metrics (Prometheus) + structured logging (slog) + optional tracing.
- **Rate-limiting** — per-IP/token throttle + login brute-force limiter; decide HELIX_MAX_INFLIGHT default (K14).
- **Auth hardening** — hashed password storage + durable refresh-token store (or wire the real auth brick).
- **Device-side min_current_version** — add to ota-protocol.UpdateAvailable + Kotlin DTO + device enforcement (§2.3).
- **Complete §11.4.169 gaps** — server distributed-DDoS, submodule benchmarks/memory, web-surface stress/chaos (§3).
- **HB-1 fw_setenv flush-error fix** after §11.4.8 research (K7).

P2 — On-device OTA e2e live validation (T1 / main; hardware-gated) — effort M–L (elapsed)

- **RK3588 Tier-3 on-silicon A/B apply** (vendor HAL, U-Boot slot-switch, real-partition dm-verity) — OTA-004 (OPERATOR-BLOCKED on board).
- **Wire the Linux ApplyPort SlotWriter** + driver loop (server/internal/device/applyport.go scaffold, §2.4) once fw_env.config + RAUC bundle are validated.
- **Android bricks real-device coverage** (stress/chaos/bench/memory + instrumentation) on a real target (§3).
- **§11.4.185 manual QA-team confirmation** on D1/D2 as the final release gate (K10).

P3 — Accounts multi-tenant (T2 / feature/multi-tenant-accounts; isolated §11.4.167 stream) — effort XL

Resolve the K12 decision gate FIRST, then the 8 milestones (accounts/30_delivery_plan.md), critical path M1→M2→M3→M7-storage-seam→M5/M6 e2e→M8: - **M1 (XL)** data model + 002/003 migrations + store.Repository

account scoping + RLS. - **M2 (L)** authZ / token account_id claim / super-admin + single role-vocab SSOT. - **M3 (L)** account-scope every OTA route + super-admin /admin/* API + GET /artifacts list. - **M4 (L)** UI: sign-in split + account switcher + super-admin console (dashboard + ota-manager), host-render-proven light+dark. - **M5 (M)** project-side integration CLI (server/cmd/helix-ota). - **M6 (XL)** device/System update client + setup wizard (ota-android-agent) + per-account key verify. - **M7 (L)** security hardening + **object-storage seam** (MinIO/S3, real StorageRef, per-account signing-key registry, secret fail-fast) — pull the storage seam EARLY (right after M3) so M5/M6 e2e aren't permanently SKIP. - **M8 (M-L)** full §11.4.40 retest + §11.4.185 manual-QA final gate + operator-approval merge to main.

P4 — Marketing website §11.4.190 (T4 / feature/website; new submodules/website) — effort L

Resolve the K13 decisions, then: scaffold Angular 22 SSR + Tailwind v4 + OpenDesign Helix-green brand layer; build content to the locked spec (contact@hxota.com, no pricing, heart footer, roadmap-marked claims); i18n + theme switchers + WCAG-AA + Core Web Vitals; §11.4.190 proofs (responsive breakpoint×engine host-render + automated SEO audit + light/dark §11.4.170 pixel proof).

P5 — Hardening backlog + docs/tracking hygiene (T3/T4 + T1) — effort M

- **Containers** (T3): land SW6-1 (pkg/lifecycle/idle.go recover) + remaining Wave-21/22 findings; merge feature/containers-hardening → main (§11.4.191), bumping the containers gitlink.
 - **vm/emu** (T4): SW1-2 macos timer (K8), SW2-2 authorizeADB diagnostic, Wave-16/17/18 backlog.
 - **Tracking** (T1): load docs/workable_items.db from this plan via cmd/workable-items (§11.4.93); wire this doc as the §11.4.172 living plan; complete §11.4.153 per-feature video-recording confirmation (durable evidence).
-

6. WORKABLE-ITEMS BREAKDOWN (load-list for docs/workable_items.db via cmd/workable-items)

ATM IDs left <auto> (the tool allocates). Track/branch per §5 (reconcile §2.9 first). Description ≥40 chars, plain-language (§11.4.171).

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
1	Bump llm_orchestrator parent gitlink to c41a264	Task	Medium	T1	main	The parent repo points at an older llm_orchestrator commit (7e3e6da) while the submo tip is c41a264 which landed Wave-22 to advance the gitli main carries the The progress led, claims a Wave-21 containers comm that does not exist the main checker reconcile the ledger and confirm the hardening lives of the feature branch pending merge. Comments still describe the old exclusive-lease behavior that HE already made uniform; correct them so future readers do not re-introduce the divergence the c already fixed.
2	Reconcile containers gitlink ledger note vs main tree	Task	Low	T1	main	
3	Fix stale fabric-lease comments (postgres_fabric/store)	Bug	Low	T1	main	A stage comment falsely claims the protocol layer
4		Bug	Low	T1	main	

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
	Correct VAL-1 false comment in ota-artifact-validator					enforces a version length bound; fix name the real in-package guard so future edit does not silently drop that protection.
5	Mirror-fork canonicalization decision + union-merge	Task	Medium	T1	main	Three owned submodules have cross-org divergent mirrors blocking clean publish; the operator must pick one canonical mirror per repo and the divergent branches be union-merged or retired without a force-push.
6	Remove stray untracked submodules/LLMProvider dir	Task	Low	T1	main	An untracked duplicate LLMProvider directory sits besides the tracked llm_provider submodule; remove the stray copy after confirming nothing depends on it.
7	ROLL-1 decision: SuccessThreshold==0 canary semantics	Task	Low	T1	main	A zero success-threshold currently lets any single success pass a canary phase with no rejection; decide whether to reject that commit or document it as intended symmetric behavior.
8		Task	Low	T2	feature/ multi-	The static multitier config, the operator

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
	Reconcile track/ branch bindings + record canonically				tenant-accounts	directive, and the accounts delivery plan name differ branches for the same work; reconcile them and record canonical track/branch binding per logic group in the registry.
9	Provision multi-track toolkit aliases (OAuth)	Task	Medium	T1	main	The multi-track headless ruler is bootstrapped but per-alias worker accounts are not provisioned; the operator must supply the toolkit OAuth tokens so the automatic multi-orchestration can engage.
10	Migrate OTA-003 to Fixed.md + refresh Status/ CONTINUATION	Task	Low	T1	main	The completed Cuttlefish Tier-2 still sits in the open tracker and the feature-status docs are weeks stale; migrate the closure and re-export the tracking docs so they reflect live state.
11	Add graceful shutdown (SIGTERM drain) to ota-server	Task	High	T1	main	The server has no signal handling or connection drain so a rolling deployment SIGTERM drops in-flight requests; add http.Server.Shutdown for both the

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
12	Fail-fast on default/unset token signing secret	Bug	High	T1	main	HTTP and QUIC transports. When the token signing secret env var is unset the server silently signs with a publicly-known key; make it refuse to boot (or loudly warn) so production never runs with a forged signing key.
13	Add observability: metrics, structured logs, tracing	Feature	High	T1	main	The control plane exposes no metrics, traces, or structured logs, leaving a flakey update system operationally blind; add a Prometheus metrics endpoint, structured logging, and optional distributed tracing.
14	Harden rate-limiting: per-IP throttle + brute-force guard	Feature	Medium	T1	main	Only a global in-flight semaphore exists; it defaults to disabled, with no login brute-force protection; add per-IP/token throttling, login attempt limit, and a safe default flight cap.
15	Auth hardening: hash passwords + durable refresh store	Feature	Medium	T1	main	The MVP auth keeps plaintext passwords in memory and lazily refreshes tokens on restart; hash store credentials and persist refresh tokens (or wire the real

#	Proposed title	Type	Severity	Track	Branch	Description (≥400 chars)
						brick) for a production identity path.
16	Add device-side min_current_version to UpdateAvailable	Feature	Medium	T1	main	The server enforces a minimum-current-version floor but never sends it in a wire offer, so the device cannot enforce it locally. The field to the protocol and Kotlin DTO and enforced device-side.
17	Wire Linux/U-Boot ApplyPort slot-writer + driver loop	Feature	Medium	T1	main	The on-device Linux apply path is a documented scaffold with stubbed slot-writer and driver. Implement the full U-Boot apply loop once fw_env config and RAUC bundle are validated.
18	Resolve applyport CLI placeholder return	Task	Low	T1	main	The applyport CLI tool returns a placeholder value on one path; implement the real behavior so the CLI is complete and not a partial stub.
19	Complete §11.4.169 test-type coverage gaps	Task	Medium	T1	main	Several surfaces test types the standard requires (distributed DDoS on the server, benchmarks/metrics on the Go bricks, stress/chaos on the web apps); add the

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
20	HB-1 fw_setenv flush-error handling (research-gated)	Bug	Medium	T1	main	missing types with captured evidence SaveEnv swallow fw_setenv flush error, but a naive false-fails on backends where empty-key save is unsupported; research the tool semantics first, then apply a fix that fails only on real errors
21	RK3588 Tier-3 on-silicon A/B apply validation	Task	High	T1	main	The full on-hardware update path (vendor HAL, U-Boot slot-switch, real-partition dm-verity, auto-rollback) is unproven and hardware-blocked; validate on a physically attached Orange Max board.
22	Android bricks real-device test coverage	Task	Medium	T1	main	The Android age and update-engine bridge have only unit tests; add stress chaos, benchmark memory, and instrumentation coverage against real Android A/B target.
23	\$11.4.185 manual QA-team final confirmation gate	Task	High	T1	main	No scope is released complete until the team manually confirms it on real hardware; hand off the validated build QA on the D1/D2

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
						boards and record the final confirmation before any tag.
24	Accounts: resolve operator decision gate	Task	High	T2	feature/multi-tenant-accounts	The multi-tenant design is complete but implementation is gated on operator choices for permission model, identity source, migration path, project account keys, and account type; resolve these before M1 starts.
25	Accounts M1: data model + migrations + store scoping	Feature	High	T2	feature/multi-tenant-accounts	Add account/user membership entities and account-and-project scoping columns across every OTA table in both store backends with RLS, the keystone that everything else depends on.
26	Accounts M2: token account-claim + super-admin authZ	Feature	High	T2	feature/multi-tenant-accounts	Add the account-scoped token claim, the super-admin bypass, and a single canonical role vocabulary across server and both stores so requests authorized only their own account.
27	Accounts M3: scope every OTA route + super-admin API	Feature	High	T2	feature/multi-tenant-accounts	Gate every OTA route by the account claim, add the super-admin API and account-selection endpoints, and the

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
						missing list-artifact endpoint, keeping existing API backward-compatible.
						Extend both web apps with a post-account picker, an account switcher above the project switcher, and a super-admin console all proven light and dark by host-rendered pixels.
28	Accounts M4: sign-in split + account switcher + console	Feature	Medium	T2	feature/ multi-tenant-accounts	Build a production CLI that a consumer project's CI uses to authenticate to our account and project and publish OTA updates, extending the existing upload path rather than reinventing it.
29	Accounts M5: project-side integration CLI	Feature	Medium	T2	feature/ multi-tenant-accounts	Extend the device agent to a multi-account production client with a server minted identity, a notification/setup consent wizard, a per-account signature verification, so a device only ever updates its own account's updates.
30	Accounts M6: device update client + setup wizard	Feature	High	T2	feature/ multi-tenant-accounts	Replace the discard-after-validate placeholder with
31		Feature	High	T2	feature/ multi-	

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
	Accounts M7: object storage seam + security hardening				tenant-accounts	real per-account object-storage seam and signed down URLs, add the per-account signing-l registry, and fail on an unset secret
32	Accounts M8: full retest + manual-QA merge gate	Task	High	T2	feature/multi-tenant-accounts	Run the complete sweep from a clean baseline with captured evidence and the manual-final confirmation then merge the feature branch to main only after operator approval
33	Website: resolve the three operator decisions	Task	Medium	T4	feature/website	The marketing website plan is complete but blocked on operator choice for the new repository remote, the containerized build approach, and the tokens-only OpenDesign strategy resolve them before scaffolding.
34	Website: scaffold Angular 22 submodule + brand tokens	Feature	Medium	T4	feature/website	Create the new website submodule with Angular 22 Tailwind v4, and Helix-green OpenDesign branding layer with light/dark and i18n switches as the base for the marketing site.
35		Feature	Medium	T4		Build the long-term marketing site

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
	Website: build content to the locked spec				feature/ website	describing only n shipping capabilities with the locked s email, no pricing heart footer, and roadmap feature clearly marked as coming.
36	Website: §11.4.190 responsive + SEO + visual proofs	Task	Medium	T4	feature/ website	Prove the site is f responsive, SEO-optimized, and enterprise-quality with host-render screenshots across the breakpoint a engine matrix, an automated SEO a and light/dark pi proofs.
37	Containers: land SW6-1 + merge hardening branch to main	Task	Medium	T3	feature/ containers- hardening	Land the idle-shutdown recover guard and remain containers harde findings, then me the hardening br to main and adva the parent gitlink under the work-t binding rule.
38	vm/emu hardening backlog (SW1-2, SW2-2, Wave-16/17/18)	Task	Low	T4	feature/ vm-emu- hardening	Work the remain vm and emulator hardening backlog including the ma boot-wait timer l the discarded AD authorize diagno and the process-l and fixture clust
39	Load workable_items.db	Task	Medium	T1	main	This plan's leaf it are not yet in the single-source-of-

#	Proposed title	Type	Severity	Track	Branch	Description (≥40 chars)
	from this plan (§11.4.93)					database; load the via the workable items tool so the tracker, docs, and living plan stay in sync. Several feature-s rows cite cleared ephemeral recordings rather than durable committed evidence regenerate window scoped, vision- verified recordings and commit them durable proof.
40	Complete §11.4.153 per-feature video- recording evidence	Task	Low	T1	main	

Counts: 40 workable items across 6 phases (P0–P5) — 14 Feature, 22 Task, 4 Bug.

7. Honest boundary (§11.4.6)

This is an **analysis + planning** deliverable. No fixes were implemented, no DB was written, no builds beyond the survey subagents' single clean go build ./.... Every claim above cites a file/path or is marked UNCONFIRMED:. Effort sizes are T-shirt estimates, not calendar commitments (§11.4.172 — replace with measured-velocity ranges once P0/P1 land). The two biggest deliverables (Accounts, Website) already carry their own detailed, operator-gated design sets under docs/research/accounts/ and docs/research/website/ — this plan cites and sequences them rather than restating them. The release tag remains gated on §11.4.185 QA-team manual confirmation and the resolution of the K1/K12/K13 operator decisions.